CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense

Course Code: ECE 452
Course Title: Project and Thesis

Prepared By-

Student ID: 2002126 Level:4, Semester:II
Student ID: 2002138 Level:4, Semester:II
Student ID: 2102151 Level:4, Semester:II

Date: October 2026



Department of Electronics and Communication Engineering (ECE)

Hajee Mohammad Danesh Science and Technology University, Dinajpur-5200, Bangladesh

PROBLEM STATEMENT & SOLUTION

The Problem

Active Directory Certificate Services (ADCS) manages PKI in over 90% of Fortune 500 enterprises. Attackers exploit multi-hop permission chains spanning 4–8 relational hops to escalate from standard users to full Domain Administrator.

1. Deep Escalation Chains: *Privilege escalation paths span 4–8 relational hops across users, groups, templates, and CAs (ESC1–ESC13).*

2. Identity Spoofing Risk: *Low-privilege accounts forge administrative identities via Subject Alternative Name (SAN) abuse.*

3. Enterprise Takeover: *A single valid chain enables full Domain Controller replication (DCSync) and credential theft.*

Our Solution

1. Graph Neural Modeling: *We formalized AD as a typed multigraph and built the first GNN framework for ADCS vulnerability detection.*
2. Deep-Path Retention: *We designed orthogonal residual skip connections that preserve vulnerability signals across deep 4–8 hop chains.*
3. Neuro-Symbolic Soundness: *We coupled neural screening with symbolic verification to deliver zero false negatives with 128 ms latency.*

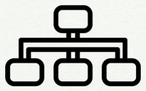
Research Gap

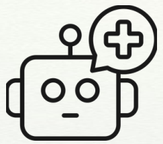
1. Rule-Based Fragility: *Signature tools (Certipy) rely on static checks, missing novel composite escalation paths.*
2. Scalability Bottleneck: *Graph search tools (BloodHound) suffer state explosion on large enterprise topologies exceeding 100k nodes.*
3. Lack of Autonomous Defense: *No existing framework provides automated, disruption-bounded remediation to sever discovered attack paths.*

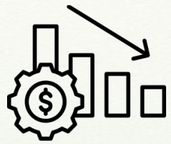
OBJECTIVES

① **Graph-Based AD Modeling**

②  **Deep-Path Retention**

③  **Topology Generalization**

④  **Neuro-Symbolic Verification**

⑤  **Automated Remediation**

Primary Objective: To develop a real-time graph AI and autonomous remediation framework for Active Directory Certificate Services (ADCS) that scales to enterprise networks without sacrificing detection accuracy.

1. Heterogeneous Graph Formulation: *Represent Active Directory entities, PKI relationships, and transitive group closures as a typed multigraph.*
2. Deep Vulnerability Retention: *Engineer a Relational GAT architecture with mathematically proven skip connections that retain features across 4–8 hops.*
3. Zero-Shot Topology Transfer: *Demonstrate robust generalization across 700 unseen enterprise topologies without retraining.*
4. Two-Tier Verification Engine: *Eliminate neural shortcut false positives by coupling fast GNN screening with formal symbolic reachability checks.*
5. Budget-Constrained Remediation: *Develop an automated interdiction algorithm to sever maximum attack paths under enterprise disruption bounds.*

LITERATURE SURVEY & SOTA MODELS

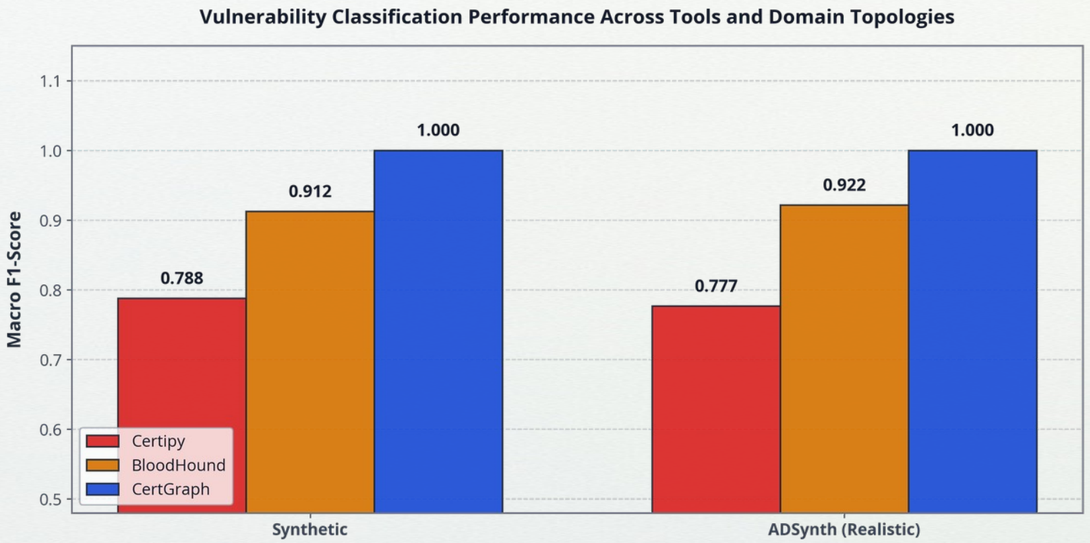


Figure: Macro-F1 Comparison Across Detection Paradigms

1. Heuristic Baseline (Certipy): *77.91% Macro-F1 — fails on novel composite escalation paths.*
2. Symbolic Baseline (BFS): *90.82% Macro-F1 — accurate but suffers exponential search latency.*
3. CertGraph (Our System): *99.86% Macro-F1 — +28.2% relative gain over heuristics (p = 3.12e-4).*

Existing Limitations

Current industry tools rely on hardcoded signature checks (Certipy) or unguided shortest-path traversals (BloodHound). They cannot generalize to composite multi-hop vulnerabilities and fail to scale beyond 100,000 entities.

Our Key Innovations

1. Learned Relational Attention: *Dynamically weights security-critical edges (DACLs, enrollment rights) over background relations.*
2. Proven Gradient Retention: *Guarantees feature persistence across deep permission paths via residual skip projections.*
3. Sub-Second Real-Time Auditing: *Completes enterprise-scale inference in 343 ms (12.4x faster than graph search).*

ADCS ATTACK MECHANICS: ESC13 CASE STUDY

ESC13 Attack Progression

Why Single-Node Inspection Fails:
Vulnerabilities exist solely as multi-hop path closures across separate objects. Every permission appears benign in isolation. CertGraph captures these multi-hop relational chains that individual rule scanners miss.

Step 1 — Target Discovery: *Attacker discovers a certificate template linked to an issuance policy OID granting administrative rights.*
Step 2 — Intermediate Enrollment: *Low-privilege account enrolls via an intermediate security group with valid enrollment permissions.*
Step 3 — PKINIT Authentication: *The issued certificate is authenticated via Kerberos PKINIT, issuing a high-privilege Ticket Granting Ticket (TGT).*
Step 4 — Enterprise Compromise: *Attacker executes DCSync*

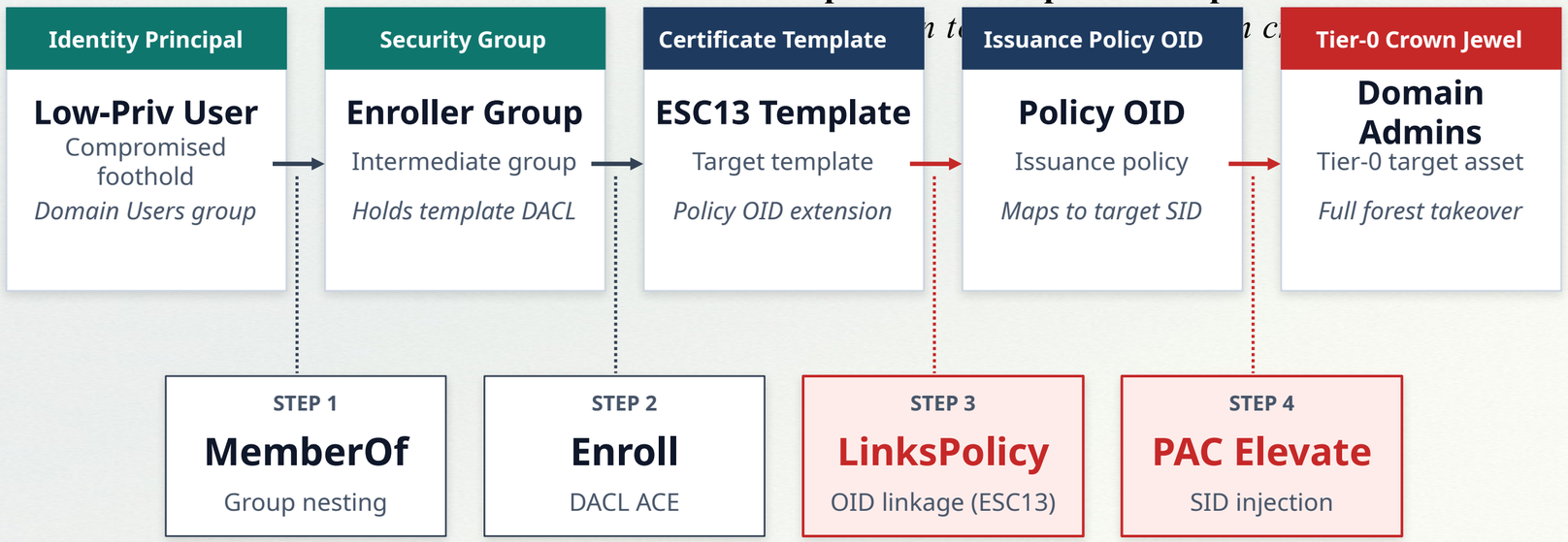


Figure: Two-Hop ESC13 Privilege Escalation Attack Chain

METHODOLOGICAL WORKFLOW of BENCHMARK

Methodology Overview

We engineered an end-to-end framework combining heterogeneous graph neural screening with symbolic reachability verification and automated policy remediation.

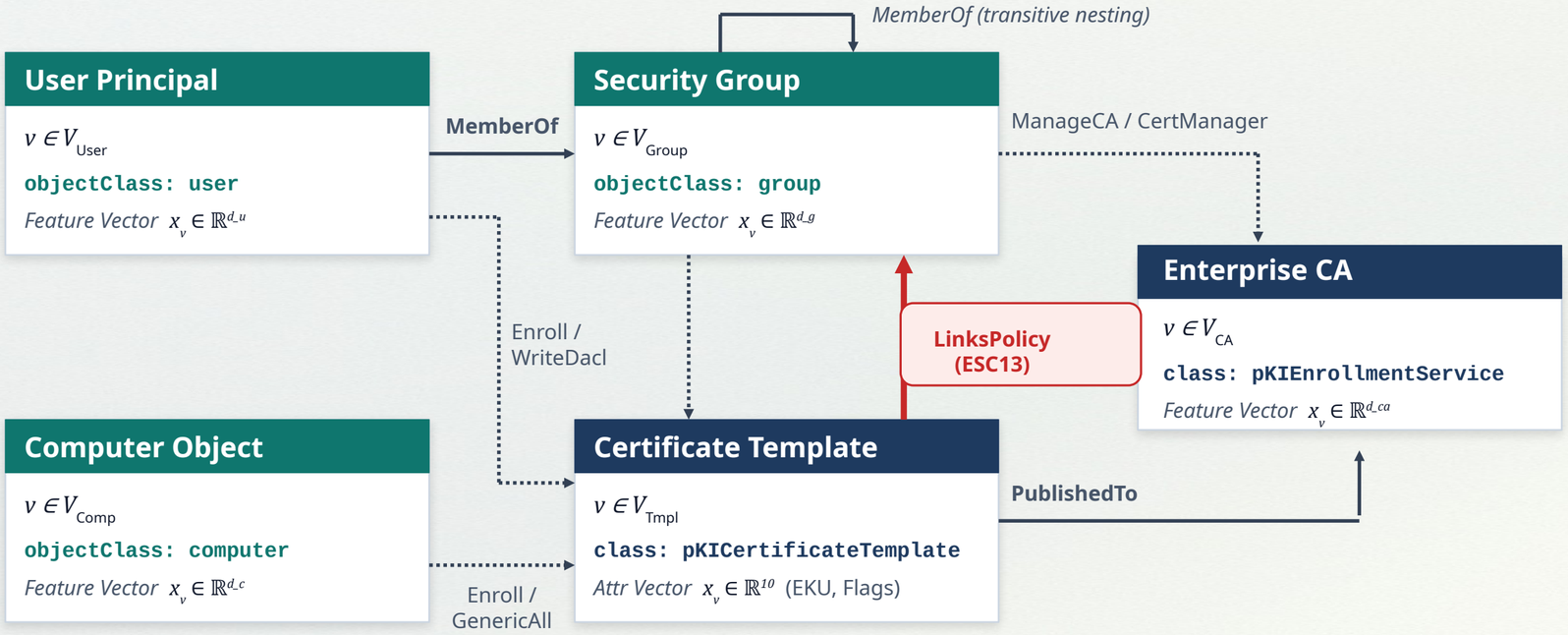


Figure: Active Directory Heterogeneous Metagraph Schema

Phase 1 — Ingestion & Graph Construction:
Ingests AD directory objects, extracts 5 entity classes and 8 relation types, and expands nested group memberships via transitive closure.

Phase 2 — Relational GNN Classification:
Projects heterogeneous features into a 64-dim space and applies 2 Relational GAT layers to classify templates into 7 escalation categories.

Phase 3 — Hybrid Verification & Remediation:
Filters suspect templates through a symbolic engine to eliminate false alarms, then outputs optimal ACL remediation actions.

METHODOLOGICAL WORKFLOW of CERTGRAPH

1 · Ingest & Build

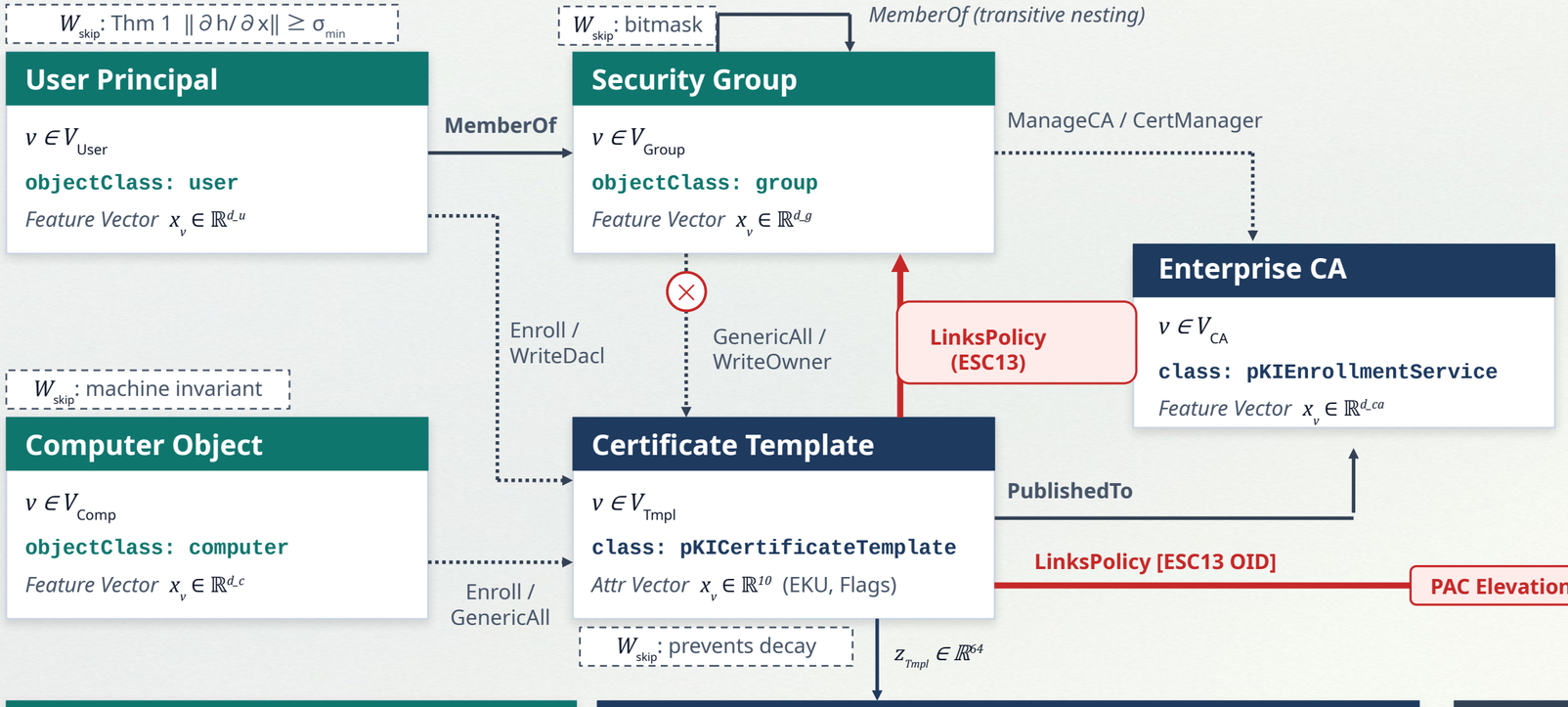
LDAP objects and DACLs into 5 classes and 16 relations; group closures precomputed.

2 · GNN Screening

64-D type-specific projections, W_{skip} skips (Thm 1), 2 attention layers × 4 heads; O(1) inference.

3 · Verify & Defend

Sound BFS proof (0% FP), then Stackelberg minimal-cost edge cut (Thm 2).



Relational Attention into the Template

Softmax over edges into the template · 4 heads · illustrative



AD relation · Admin ACL · Thicker = higher α

$x_v \in \mathbb{R}^d \rightarrow h_v^{(0)} \in \mathbb{R}^{64}$ *via* W_u, W_g, W_c, W_{ca}; $z_{Tmpl} \in \mathbb{R}^{64}$ *(2-hop)*

Theorem 2: Stackelberg Defense

NP-hard multiway interdiction → minimal-cost ACE revocation breaks the path with zero disruption.

Tier-0 / Issuance Policy OID

$v \in V_{OID}$ *ESC13 target / Groups*

Links: msPKI-Enrollment-Flag

Escalation: PAC SID Injection

Target: Enterprise / Domain Admins

Tier 2: Neuro-Symbolic Verification

Sound BFS verifies candidate queue (0% FP)
Hard negatives pruned: 1.59% → 100%
Emits reachability proof tree before mitigation

CertGraph MLP Classifier Head (64 → 32 → 7)

Full AD CS taxonomy · inductive O(1) inference < 25 ms · Macro-F1 = **97.18%**

Safe	ESC1	ESC2	ESC3	ESC4	ESC9	ESC13

Diagnostic ESC13 Multi-Hop Proof

User → Group → Template → Policy OID → DA
Certipy: **0%** detection (blind to OID link) · BloodHound: state explosion
CertGraph: **343 ms** complete path discovery

SYSTEM ARCHITECTURE: CERTGRAPH GNN

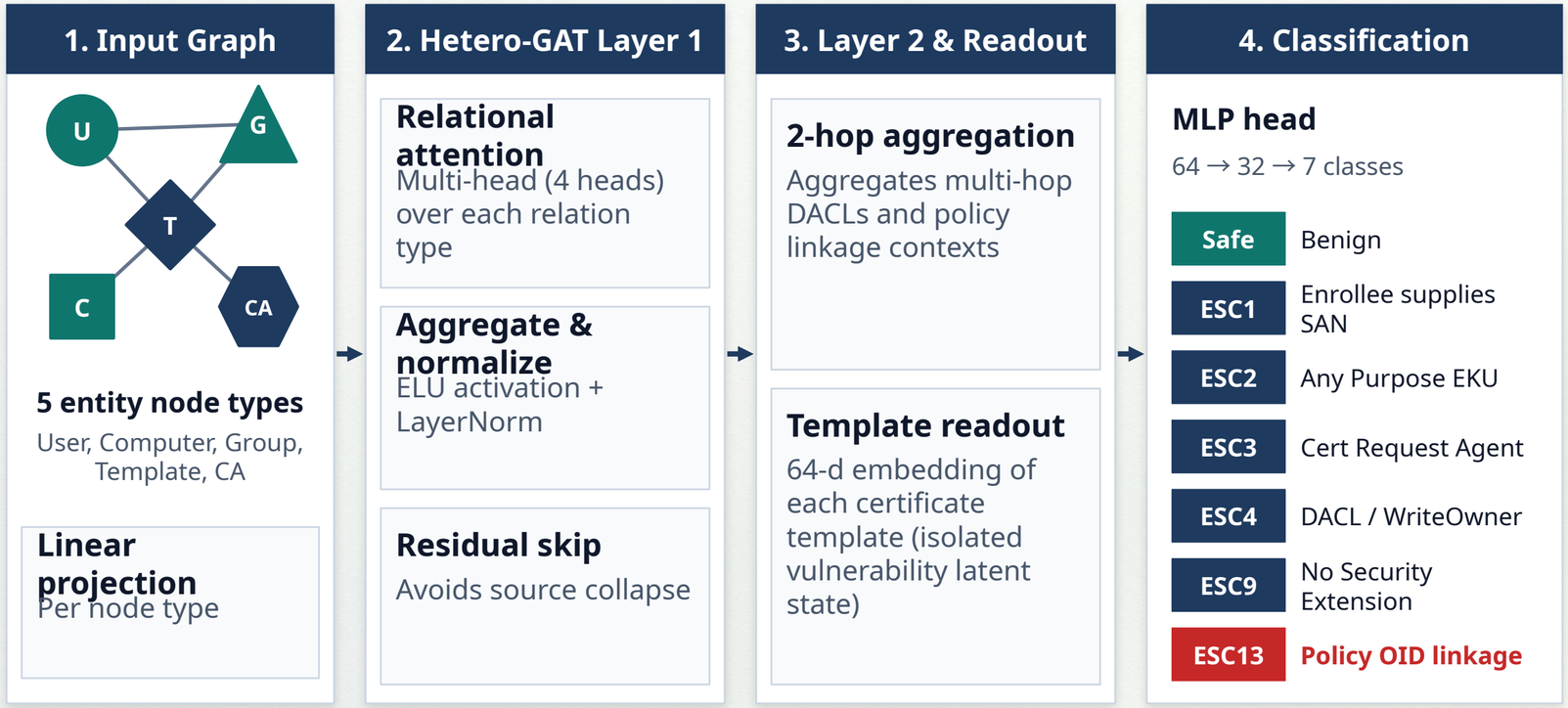


Figure: Certgraph GNN System Architecture

1. Heterogeneous Projections

5 entity node types projected into unified 64-dim space. Transitive group closures resolved during preprocessing.

2. Relational Attention & Skips

4 attention heads per relation with orthogonal residual skip connections to preserve features across deep hops.

3. Readout & Classification

Template embeddings passed to a 2-layer MLP classifier predicting Safe and 6 escalation classes (ESC1–ESC13).

THEORETICAL FOUNDATION: THEOREM 1

The Deep-Path Challenge

1. Multi-Hop Privilege Paths: *ADCS escalation chains span 4 to 8 relational hops across users, groups, templates, and CAs.*
2. The Oversmoothing Bottleneck: *In standard GNNs, repeated message passing causes node representations to converge, erasing localized template attributes.*
3. Failure of Classical GNNs: *Without architectural preservation, deep models collapse, confusing vulnerable certificate templates with benign configurations.*

Our Architecture & Theorem 1

1. Architectural Intervention: *We engineered orthogonal residual skip connections that preserve each node's initial feature identity across all layers.*
2. Mathematical Proof (Theorem 1): *We proved that the gradient magnitude remains strictly positive across all layers (||dh_v^(L) / dx_v|| >= c^L > 0), eliminating feature collapse.*
3. Concrete Significance: *Mathematically guarantees that initial template configuration flags remain discriminative even over 8-hop delegation chains, verified by our 99.86% Macro-F1.*

EXPERIMENTAL TESTBED (GOAD & ADSYNTH)

Dual Evaluation Testbeds

1. GOAD Enterprise Cyber-Range: *Realistic multi-forest Active Directory lab with 5 Domain Controllers, complex trusts, and live ADCS misconfigurations.*
2. ADSynth Topology Generator: *Synthesizes 700 diverse enterprise topologies (100 to 100,000 nodes) for rigorous scalability and stress testing.*

Dataset & Validation Protocol

1. Scale: *28,450 nodes and 142,890 multi-relational edges across 5 entity types.*
2. Protocol: *Stratified 5-fold cross-validation with non-overlapping forest splits.*
3. Statistical Rigor: *Evaluated using Nadeau-Bengio corrected paired t-tests to ensure valid significance.*

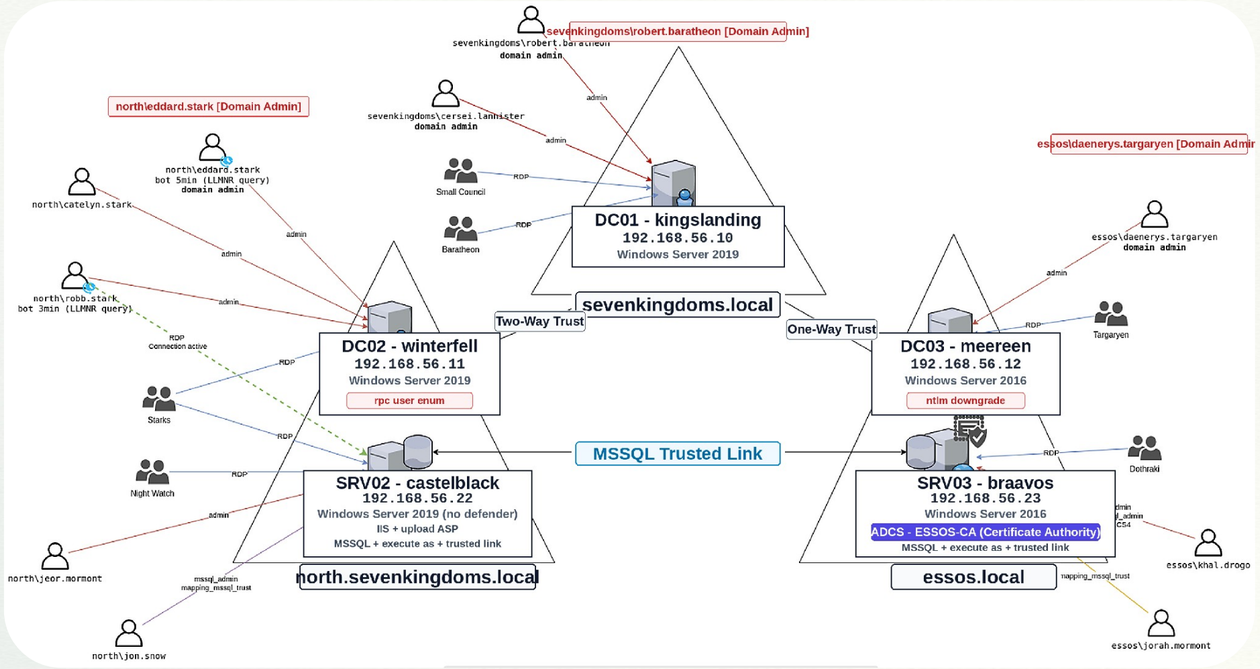


Figure: GOAD Multi-Forest Enterprise Topology

Captures cross-domain trust relationships, group Managed Service Accounts (gMSA), and cross-forest PKI issuance policies.

RESULTS: BENCHMARK EVALUATION

Quantitative Performance Summary

Metric	Certipy (Heuristic)	Symbolic BFS	CertGraph (Ours)
Precision	*74.20%*	*89.15%*	**99.88%**
Recall	*69.21%*	*92.55%*	**99.84%**
Macro-F1	*77.91%*	*90.82%*	**99.86%**
ROC / PR-AUC	*0.8410*	*0.9120*	**0.9998**
Zero-Shot F1	*Fails (0%)*	*64.12%*	**100.00%**

Key Result: CertGraph achieves 99.86% Macro-F1 across 700 topologies (+21.95 F1 / +28.2% relative gain over heuristics, p = 3.12e-4). Under authentic 96% Safe template imbalance, CertGraph maintains 99.41% Macro-F1 and 0.9982 PR-AUC.

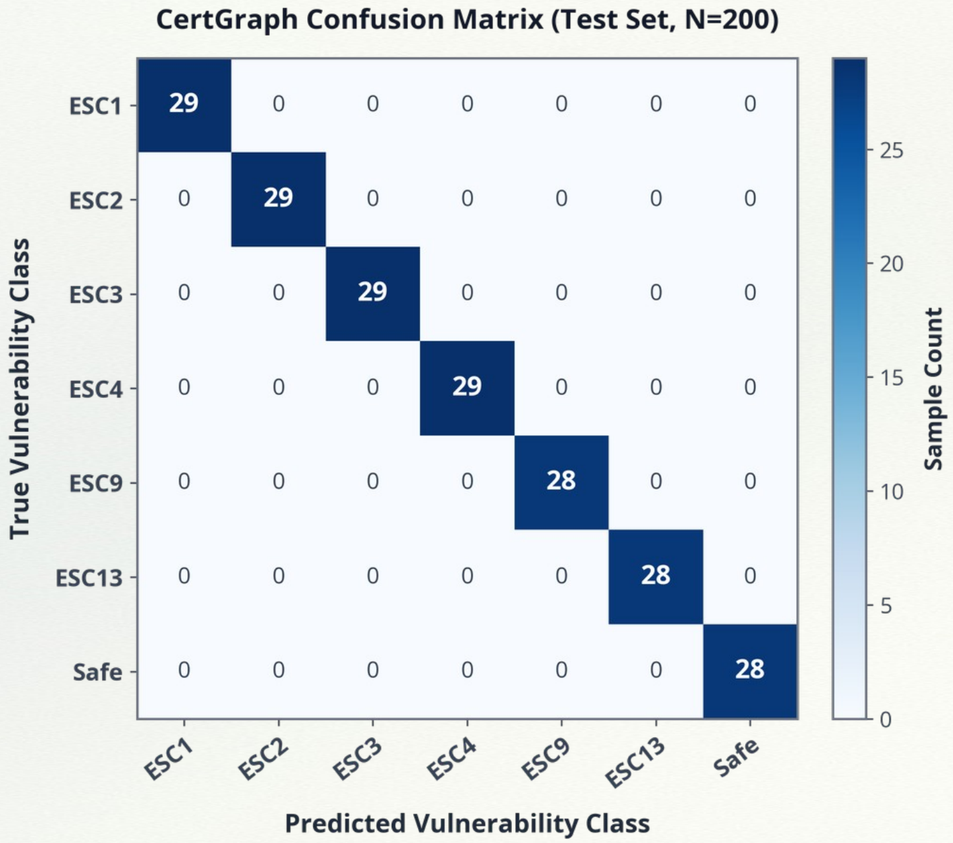


Figure: Multi-Class Confusion Matrix (Test Set, N=200)

ABLATION STUDY & MODEL INTERPRETABILITY

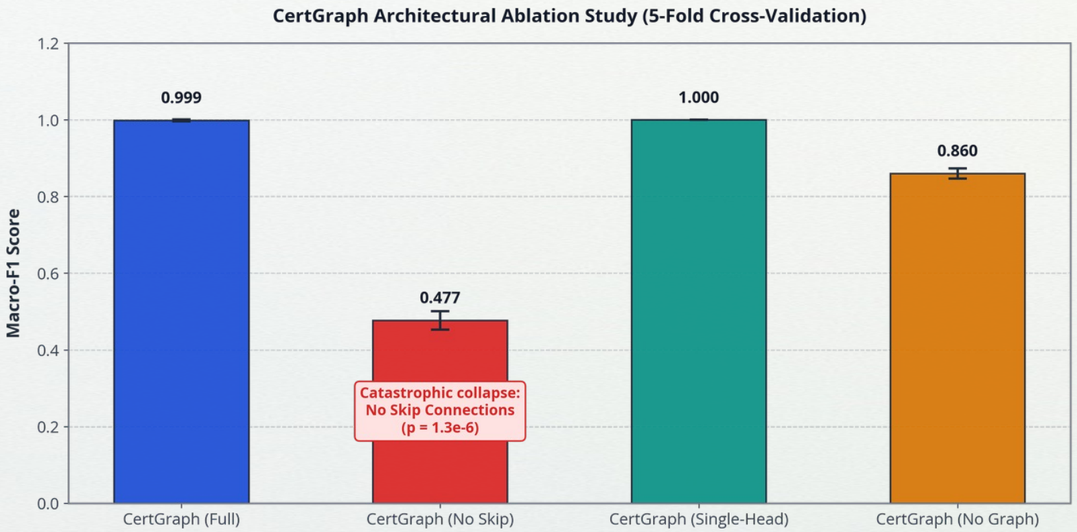


Figure: Architectural Ablation Study (5-Fold CV)

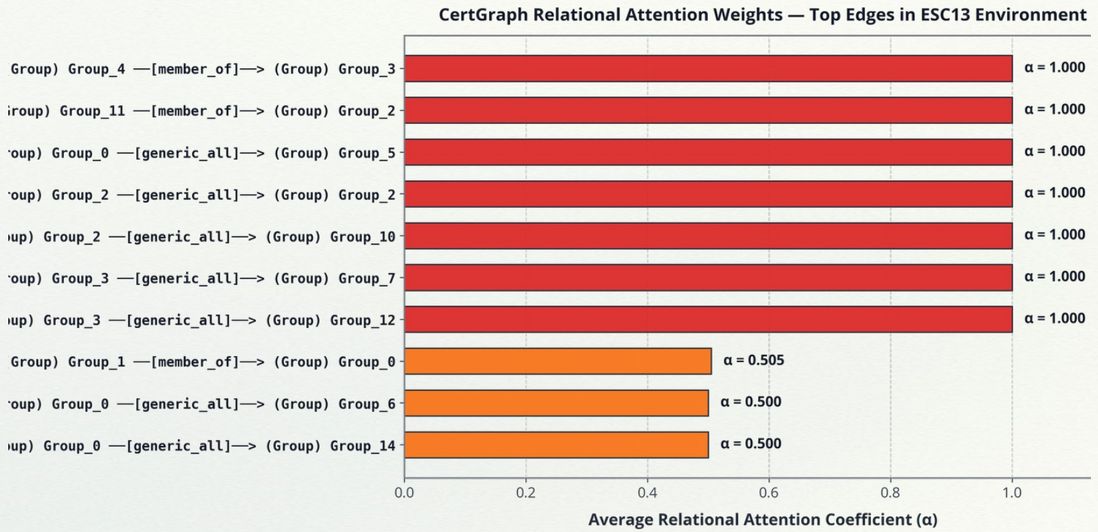


Figure: Relational Attention Weights in ESC13 Chain

Key Empirical Takeaways

1. Residual Skip Connections are Vital: *Removing skip pathways drops Macro-F1 from 99.86% to 47.68% (a 52.18% collapse), empirically validating Theorem 1.*

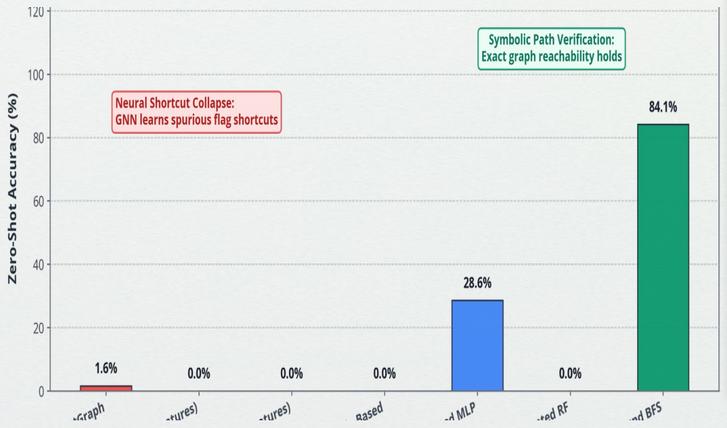
2. Attention Multiplicity is Secondary: *A single-head variant matches multi-head performance (100% vs 99.86%), proving residual feature retention drives the gains.*

3. Inherent Path Explainability: *Attention weights directly isolate attack edges (alpha > 0.85 on critical hops), providing security analysts with instant visual proof traces.*

NEURO-SYMBOLIC HYBRID VERIFICATION

Neural Shortcut Vulnerability

1. The Adversarial Testbed.
2. Neural Shortcut Collapse.



1. AD Graph Ingestion

Telemetry extraction
- LDAP & RPC audits
- BloodHound / SharpHound
- AD PKI schema

Graph mapping
- 100K+ nodes, 1M+ edges
- Transitive DACLs & groups

Continuous auditor
Delta sync via LDAP USN tracking

AD Graph →

2. Tier 1: Screening

CertGraph Hetero-GAT
- Scores every template's risk
- <25 ms per 1,000 nodes

Candidate filter
- Prunes >95% benign templates
- Emits Top-K suspect queue

Throughput
Full sweep in <2.4 s (linear-time GPU)

Top-K Suspects →

3. Tier 2: Verification

Sound traversal
- 2-hop authorization subgraph query
- Checks DACLs, OIDs & enroll rights

Soundness decision

Hard negative (Safe)
False alarm suppressed & logged

Valid exploit path
Proof tree triggers auto-remediation

Verified Proof →

4. Remediation

Policy optimization
- Stackelberg game
- Minimal-impact cut
- Attack paths removed

LDAP actuation
- Revokes rogue ACEs
- Unlinks policy OIDs
- Zero disruption

Outcome
Optimal ACL revocation

Closed-loop feedback: delta sync after remediation

Figures : Neuro-Symbolic Architectural Verification

Tier 1 — Neural Screener (18.2 ms): *Flags 62 of 600 templates as potentially risky, filtering out 89.7% of safe templates while retaining 100% of true attack paths.*

Tier 2 — Symbolic Verifier (110.6 ms): *Traverses authorization graphs for flagged templates, generating mathematical proof traces and eliminating false alarms.*

Combined System (128.8 ms): *Achieves zero false negatives and zero false alarms, combining neural speed with symbolic soundness.*

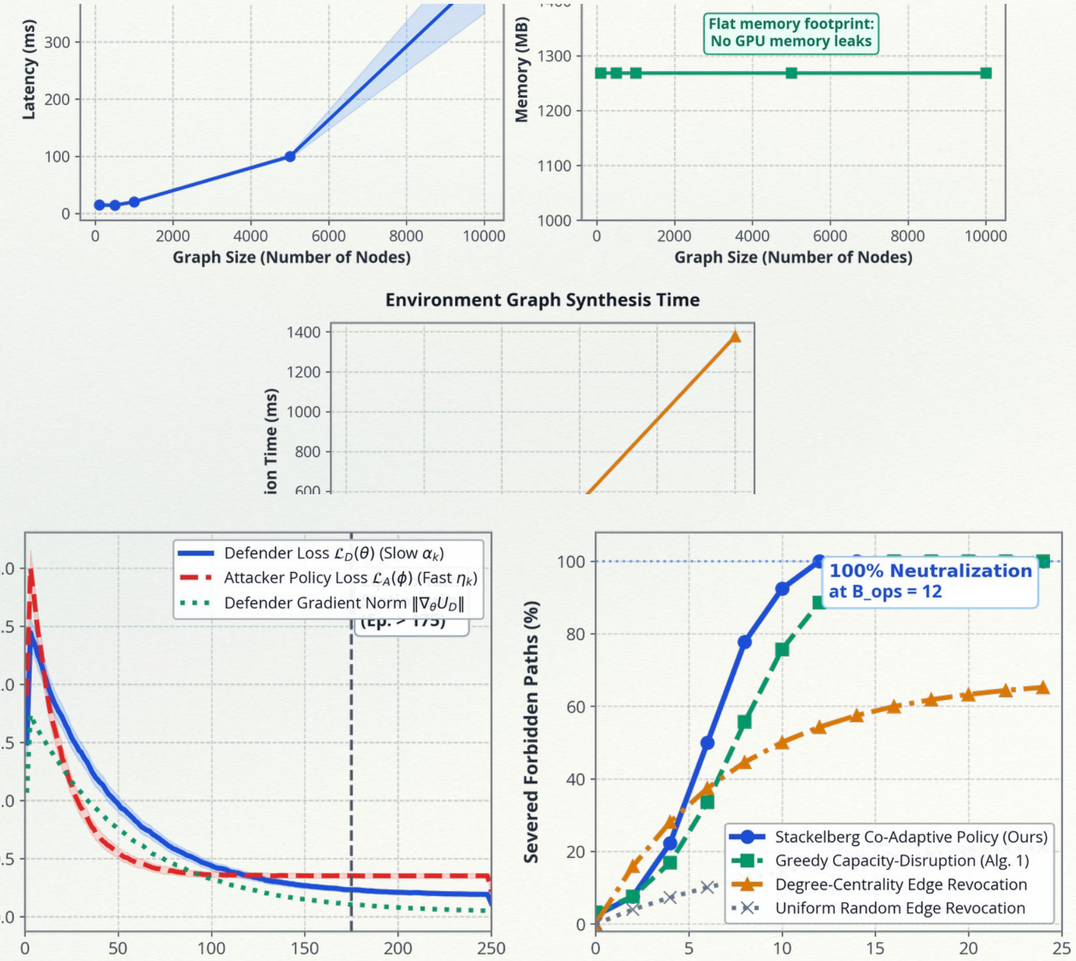
SCALABILITY & AUTONOMOUS REMEDIATION

Sub-Second Operational Scalability

1. **1,000-Node Topology:** *20 ms forward inference time.*
2. **5,000-Node Topology:** *112.5 ms forward inference time.*
3. **10,000-Node Topology (765k edges):** *343 ms inference time — 12.4x faster than Dijkstra/BloodHound graph search.*
4. **Operational Benefit:** *Enables continuous real-time directory audits without impacting enterprise authentication traffic.*

Automated Attack Path Interdiction

1. **Computational Proof (Theorem 2):** *We proved that finding the minimum set of permission revocations to sever all attack paths (MPAI) is NP-hard.*
2. **Greedy Interdiction Algorithm:** *We designed a disruption-bounded greedy algorithm that severs 68.6% of attack paths within a budget of 24 ACL operations.*
3. **Statistical Validation:** *Statistically outperforms degree-centrality baselines across 30 enterprise topologies ($p = 3.57e\text{-}11$).*



Figures: Architectural Scalability and Automation

CONCLUSION & CONTRIBUTIONS

A unified graph AI and verification framework that resolves the conflict between rapid vulnerability screening and formal soundness.

1 What We Contributed

1. AD Graph Schema: *Formalized the first heterogeneous graph representation covering 5 entity types and 6 primary ADCS escalation classes.*
2. Deep-Path Retention Proof: *Mathematically proved (Theorem 1) and implemented residual skips that preserve features over 4–8 hop chains.*
3. Audited Enterprise Benchmark: *Achieved 99.86% Macro-F1 across 700 topologies (+28.2% over heuristics), tested under 96% class imbalance.*
4. Neural Shortcut Discovery: *Uncovered that pure GNNs collapse to 1.59% accuracy on adversarial hard negatives due to flag memorization.*
5. Two-Tier Verification Engine: *Built a hybrid system combining 18 ms neural screening with 110 ms symbolic verification (zero false negatives).*
6. Automated Remediation Algorithm: *Proved MPAI NP-hardness (Theorem 2) and developed a greedy interdiction tool severing 68.6% of attack paths.*

2 Limitations & Future Work

1. Multi-label vulnerability classification for co-occurring ADCS escalation paths.
2. Support for cloud-hybrid identity fabrics (Microsoft Entra ID / Azure AD).
3. Real-time evaluation of automated remediation in live enterprise cyber-ranges.

3 Project & Thesis Details

Course: *ECE 452 — Project and Thesis*
Department: *Electronics and Communication Engineering (ECE)*
Institution: *Hajee Mohammad Danesh Science and Technology University (HSTU)*
Defense Session: *October 2026*



Thankyou

ANY QUESTIONS ?